

Security+ 4.3 · Analyzing Vulnerabilities

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.3 — Analyzing Vulnerabilities**
(10:29) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: CVSS 0-10: baixo 0.1-3.9; médio 4-6.9; alto 7-8.9; CRÍTICO 9-10. CVE=catálogo mundial. Prioriza por CVSS+exposição: crítico na internet = ontem.

Highlights que a prova cobra

- CVSS 9+ = crítico; 7+ = alto
- Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)

Dicas de prova & Cenários Típicos

- 'CVSS score of 9.8'=Critical

Cenário clássico de exame: 'vulnerability com CVSS 9.8 no servidor da internet'=crítico
— patch hoje.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.3 — Analyzing Vulnerabilities)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **CVE:** Common Vulnerabilities and Exposures: Dicionário público padronizado de vulnerabilidades de segurança da informação conhecidas.
- **CVSS:** Common Vulnerability Scoring System: Sistema numérico padronizado de pontuação de severidade de vulnerabilidades (0.0 a 10.0: Baixa, Média, Alta, Crítica).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. No sistema CVSS 3.1, uma vulnerabilidade com pontuação 9.8 é classificada como:

- A)** Baixa
- B)** Média
- C)** Alta
- D)** Crítica

2. Uma vulnerabilidade CVE-2024-1234 pontuou CVSS 3.1 como 7.5 (Alta). O que deve ser feito PRIMEIRO?

- A)** Aplicar patch imediatamente em todos os servidores
- B)** Avaliar o risco no contexto do ambiente específico
- C)** Ignorar pois não é crítica
- D)** Substituir o sistema afetado

3. Qual métrica define o tempo máximo aceitável de perda de dados em um plano de Disaster Recovery, medindo o intervalo entre os backups ou réplicas?

- A) RTO (Recovery Time Objective)**
- B) RPO (Recovery Point Objective)**
- C) MTTR (Mean Time to Repair)**
- D) SLI (Service Level Indicator)**

4. Cenário corporativo (Analyzing Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'CVSS 9+ = crítico; 7+ = alto'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Implementar a solução correspondente: CVSS 9+ = crítico; 7+ = alto...**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

5. Cenário corporativo (Analyzing Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)...**

6. Cenário corporativo (Analyzing Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'CVSS score of 9.8'=Critical'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: 'CVSS score of 9.8'=Critical...**

7. Cenário corporativo (Analyzing Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'vulnerability com CVSS 9.8 no servidor da internet'=crítico — patch hoje.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'vulnerability com CVSS 9.8 no servidor da internet'=crítico — patch hoje....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Analyzing Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'CVSS 9+ = crítico; 7+ = alto'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: CVSS 9+ = crítico; 7+ = alto...

9. Cenário corporativo (Analyzing Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)...

10. Cenário corporativo (Analyzing Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: "CVSS score of 9.8'=Critical'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'CVSS score of 9.8'=Critical...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) D — Crítica.

✓ **Por que está certa:** No sistema CVSS 3.1 (Common Vulnerability Scoring System), a pontuação base varia de 0.0 a 10.0 e é categorizada em quatro faixas: Baixa (0.1–3.9), Média (4.0–6.9), Alta (7.0–8.9) e Crítica (9.0–10.0). Uma vulnerabilidade com pontuação 9.8 está, portanto, na faixa Crítica, indicando impacto severo e explorabilidade trivial ou quase trivial, com potencial para comprometer confidencialidade, integridade e disponibilidade de forma massiva. A CompTIA Security+ exige que o profissional saiba interpretar essas faixas para priorizar a remediação.

✗ **Por que as outras estão erradas:**

- *Baixa:* A classificação Baixa no CVSS 3.1 abrange pontuações de 0.1 a 3.9. Vulnerabilidades nessa faixa geralmente exigem condições muito específicas para exploração, têm impacto limitado ou necessitam de acesso local altamente privilegiado. Uma pontuação 9.8 está muito acima desse intervalo, indicando risco extremo, não trivial. Associar 9.8 a Baixa demonstra incompreensão total da escala.
- *Média:* A faixa Média no CVSS 3.1 vai de 4.0 a 6.9. Vulnerabilidades médias podem causar danos moderados, muitas vezes requerendo interação do usuário ou condições parciais de exploração. A pontuação 9.8 ultrapassa em muito esse limite, situando-se no topo da escala. Classificá-la como Média subestimaria gravemente a urgência de correção e contrariaria a própria definição numérica do padrão.
- *Alta:* A faixa Alta no CVSS 3.1 compreende pontuações de 7.0 a 8.9. Embora seja uma classificação séria, ainda está abaixo do patamar Crítico. Uma vulnerabilidade 9.8 é considerada Crítica porque combina, tipicamente, vetores de ataque remotos, baixa complexidade, nenhum privilégio requerido e impacto alto nos três pilares da segurança. Portanto, rotulá-la como Alta é tecnicamente incorreto segundo a especificação oficial do CVSS 3.1.

2) B — Avaliar o risco no contexto do ambiente específico.

✓ **Por que está certa:** Diante de uma vulnerabilidade com CVSS 7.5 (Alta), a primeira ação conforme as boas práticas de gestão de vulnerabilidades e o syllabus da CompTIA Security+ é avaliar o risco no contexto específico do ambiente. Isso significa considerar a criticidade do ativo afetado, a exposição da rede, a existência de controles compensatórios, a probabilidade de exploração real (por exemplo, se há exploit público ou atividade de ameaças) e o impacto nos negócios. Somente após essa análise contextual é que se decide a prioridade e a estratégia de remediação, que pode incluir patch imediato, mitigação temporária ou aceitação do risco. A pontuação CVSS é uma métrica genérica e não substitui a avaliação de risco organizacional.

✗ **Por que as outras estão erradas:**

- *Aplicar patch imediatamente em todos os servidores:* Aplicar patch imediatamente em todos os servidores sem avaliação prévia é uma abordagem temerária. Patches podem introduzir regressões, incompatibilidades ou indisponibilidade de serviços críticos, além de exigirem janelas de manutenção e testes. A gestão de mudanças e a avaliação de risco contextual são obrigatórias antes de qualquer implantação em larga escala. A pressa pode causar mais danos do que a própria vulnerabilidade, especialmente se o ativo não estiver exposto ou se houver mitigações eficazes.
- *Ignorar pois não é crítica:* Ignorar uma vulnerabilidade de pontuação 7.5 (Alta) porque não é Crítica é um erro grave de priorização. A faixa Alta indica risco significativo, com potencial de comprometer seriamente o ambiente. Mesmo que não seja 9.0+, uma vulnerabilidade Alta pode ser explorada por atacantes para obter acesso inicial, escalar privilégios ou causar negação de serviço. A decisão de não agir deve ser baseada em análise de risco documentada, não em uma classificação simplista que descarta tudo abaixo de Crítica.

- *Substituir o sistema afetado*: Substituir o sistema afetado é uma medida extrema, custosa e muitas vezes inviável a curto prazo. A substituição de sistemas envolve planejamento, orçamento, migração de dados e testes, não sendo uma resposta imediata a uma vulnerabilidade. Além disso, a vulnerabilidade pode ser corrigida com patch ou mitigação, tornando a substituição desnecessária. A primeira ação deve ser sempre a avaliação contextual para então decidir a resposta proporcional, que raramente é a troca completa do sistema.

3) B — RPO (Recovery Point Objective).

✓ **Por que está certa:** A opção correta é 'RPO (Recovery Point Objective)'. De acordo com o syllabus oficial da CompTIA Security+ (SY0-701), o RPO é a métrica que define a quantidade máxima de dados que pode ser perdida em caso de interrupção, medida em tempo. Ele representa o intervalo máximo aceitável entre o último backup ou réplica e o momento da falha. Por exemplo, se o RPO é de 4 horas, significa que em um desastre, pode-se perder até 4 horas de dados, pois o último ponto de recuperação válido é de até 4 horas atrás. O RPO orienta a frequência dos backups: quanto menor o RPO, mais frequentes devem ser as cópias. É uma métrica fundamental em planos de Disaster Recovery (DR) e Continuidade de Negócios (BCP), pois quantifica a tolerância da organização à perda de dados.

✗ **Por que as outras estão erradas:**

- *RTO (Recovery Time Objective)*: O RTO (Recovery Time Objective) é o tempo máximo aceitável para restaurar um serviço ou sistema após uma interrupção. Ele mede quanto tempo a organização pode ficar sem o serviço, não a quantidade de dados perdida. Em um plano de DR, o RTO define a janela de recuperação: por exemplo, se o RTO é de 2 horas, o serviço deve ser restaurado em até 2 horas. O RTO está relacionado à disponibilidade e à continuidade, enquanto o RPO está relacionado à integridade e à perda de dados. A opção está errada porque o enunciado pergunta sobre a perda de dados (intervalo entre backups), e não sobre o tempo de restauração do serviço.
- *MTTR (Mean Time to Repair)*: O MTTR (Mean Time to Repair) é uma métrica de manutenção que representa o tempo médio necessário para reparar um componente ou sistema após uma falha. É usado em gestão de incidentes e confiabilidade, mas não define o máximo aceitável de perda de dados. O MTTR foca no tempo de reparo, não no ponto de recuperação de dados. Em segurança, o MTTR pode ser usado para medir a eficiência da resposta a incidentes, mas não substitui o RPO em um plano de DR. A opção está errada porque não aborda a perda de dados, mas sim o tempo médio de reparo.
- *SLI (Service Level Indicator)*: O SLI (Service Level Indicator) é uma métrica quantitativa que mede um aspecto do nível de serviço, como latência, taxa de erro ou throughput. É usado em SRE (Site Reliability Engineering) para monitorar a saúde do serviço e definir SLOs (Service Level Objectives). O SLI não define o máximo de perda de dados aceitável; ele mede o desempenho atual do serviço. Em um plano de DR, o SLI pode ser usado para monitorar a recuperação, mas não é a métrica que estabelece o intervalo entre backups. A opção está errada porque não se refere à perda de dados, mas sim a indicadores de nível de serviço.

4) B — Implementar a solução correspondente: CVSS 9+ = crítico; 7+ = alto....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Analyzing Vulnerabilities): CVSS 9+ = crítico; 7+ = alto.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Analyzing Vulnerabilities): Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'CVSS score of 9.8'=Critical....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Analyzing Vulnerabilities): 'CVSS score of 9.8'=Critical.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: 'vulnerability com CVSS 9.8 no servidor da internet'=crítico — patch hoje.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Analyzing Vulnerabilities): 'vulnerability com CVSS 9.8 no servidor da internet'=crítico — patch hoje..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: CVSS 9+ = crítico; 7+ = alto....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Analyzing Vulnerabilities): CVSS 9+ = crítico; 7+ = alto.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Analyzing Vulnerabilities): Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: 'CVSS score of 9.8'=Critical....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Analyzing Vulnerabilities): 'CVSS score of 9.8'=Critical.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

